



Official Incident Report

Event ID: 303

Rule Name: SOC325 - Unauthorized Cloud Region Access Attempt Detected

Table of Contents

Official Incident Report	1
Event ID: 303	1
Rule Name: SOC325 - Unauthorized Cloud Region Access Attempt Detected	1
Table of Contents	2
Alert	3
Detection	4
Verify	4
Analysis	5
Reputation Check	5
Initial Access	8
Containment	13
Lesson Learned	13
Appendix	14
MITRE	14
Artifacts	14

Alert

The alert was triggered because "POST /accounts/login" request was seen towards the system. The alert occurred due to too many requests from an unused or unsupported region with the same user in a short time. In other words, it is not because a request made here is suspicious, but because both the IP and the number of requests are suspicious. In addition, the device action is seen as "blocked" in the alert details. However, all incoming requests should be checked in detail to evaluate the alert as False Positive.

EventID :	303
Event Time :	Sep, 24, 2024, 08:21 AM
Rule :	SOC325 - Unauthorized Cloud Region Access Attempt Detected
Level :	Security Analyst
Source Address :	134.209.145.73
Destination Address :	52.15.206.21
Username :	test@letsdefend.io
Trigger Reason :	Too many access attempts with the same user were detected in a short period of time from an unauthorized (configured as "unused" or "unsupported") cloud region.
Request URL :	POST /accounts/login HTTP/1.1 403 512
Device Action :	Blocked
Show Hint	

First, the alert should be verified by checking the available logs, then the source of this traffic should be investigated and it should be confirmed whether it is legitimate or not.

Detection

Verify

First, search the logs for the request that caused the alert to be triggered. You can make a search in Log Management as shown below to find the relevant log.

The screenshot shows a log management interface. At the top, a search bar contains the query "Source Address contains '134.209.145.73' and Raw Log contains 'login'". Below the search bar, it indicates "50 events (before Sep, 24, 2024, 05:21 AM)". A message box (MSG) is displayed, showing the reason for the alert: "Suspicious activity from unused cloud region detected, connection blocked". Below this, a table of log details is shown:

α type	reason	access_denied
α source_address	policyid	1
# source_port	domain	app.letsdefend.io
α destination_address	url	/accounts/login
# destination_port	method	POST
α raw_log	user	test@letsdefend.io
	msg	Suspicious activity from unused cloud region det...

As can be seen in the log above, login attempts with the user test[.]letsdefend.io from the IP "134[.]209.145.73" to the system were blocked in the firewall. In the detail of the log, "Suspicious activity from unused cloud region detected, connection blocked" is seen as the reason for blocking. From here, it can be said that the alert is True Positive. However, you should check these blocked regions and the location of the IP to confirm this. In addition, check all incoming requests to see if the alert is really True Positive or False Positive.

Analysis

Reputation Check

Checking both the reputation record and the location of the IP from which the request came will strengthen the analysis of whether the request was sent by the attacker or the Red Team.

134.209.145.73 was found in our database!

This IP was reported 8,079 times. Confidence of Abuse is 100%: ?

100%

ISP	DigitalOcean LLC
Usage Type	Data Center/Web Hosting/Transit
Hostname(s)	9dot9insights.com
Domain Name	digitalocean.com
Country	India
City	Bengaluru, Karnataka

IP info including ISP, Usage Type, and Location provided by IP2Location. Updated monthly.

REPORT 134.209.145.73

WHOIS 134.209.145.73

IP Abuse Reports for **134.209.145.73**

This IP address has been reported a total of 8,079 times from 1,105 distinct sources. 134.209.145.73 was first reported on March 4th 2024, and the most recent report was 2 hours ago.



Recent Reports: We have received reports of abusive activity from this IP address within the last week. It is potentially still actively engaged in abusive activities.

Reporter	IoA Timestamp in UTC	Comment	Categories
✓ yzfdude1	2024-09-25 04:34:15 (2 hours ago)	Sep 24 22:33:26 b146-24 sshd[2242254]: pam_unix(sshd:auth): authentication failure; logname= uid=0 e ... show more	Brute-Force SSH
✓ applemooz	2024-09-25 04:05:04 (3 hours ago)	Sep 25 06:04:07 ns37 sshd[29019]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 ... show more	Brute-Force SSH
✓ applemooz	2024-09-25 03:41:36 (3 hours ago)	Sep 25 05:36:33 ns37 sshd[24695]: Failed password for root from 134.209.145.73 port 44986 ssh2 ... show more	Brute-Force SSH
✓ paradoxnetworks	2024-09-25 00:57:50 (6 hours ago)	2024-09-25T01:51:01.102822+01:00 pbs-bit-lib-01.int.pdx.net.uk sshd[1908153]: Invalid user test from ... show more	Brute-Force SSH

<https://www.abuseipdb.com/check/134.209.145.73>

11

/ 94

Community Score

-2

11/94 security vendors flagged this IP address as malicious

134.209.145.73 (134.209.0.0/16)

AS 14061 (DIGITLOCEAN-ASN)

IN

Last Analysis Date 17 days ago

Reanalyze

Similar

Graph

API

DETECTION

DETAILS

RELATIONS

COMMUNITY 5

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

Antiy-AVL	Malicious	BitDefender	Phishing
CRDF	Malicious	Criminal IP	Malicious
Cyble	Malicious	CyRadar	Malicious
G-Data	Phishing	GreenSnow	Malicious
IPsum	Malicious	Lionic	Malicious
SOCradar	Malicious	alphaMountain.ai	Suspicious
AlphaSOC	Suspicious	ArcSight Threat Intelligence	Suspicious

<https://www.virustotal.com/gui/ip-address/134.209.145.73>

As can be seen above, the relevant IP has been reported in AbuseIPDB and VirusTotal in categories such as malicious, SSH, phishing, and brute force in different sources. In addition, the IP was found to be located in India. Although the reputation record of the IP is not clean, it cannot be said with certainty that the requests were sent by the attacker. You can check the mail traffic in email security to confirm whether it is a Red Team activity. However, Red Team activities are usually informed to SOC teams. In addition, you can also access information about restricted zone IPs.

When the relevant IP is searched in Email Security, no mail is seen. However, when searched according to the user seen in the request, a mail with the subject "Compromised Account Alert from CTI" is seen.

Monitoring

Log Management

Case Management

Endpoint Security

Email Security

Threat Intel

Sandbox

test@letsdefend.io

OR

Detailed Search

Date	Sender	Recipients	Subject	Final Action
Sep, 22, 2024, 08:19 AM	no-reply@socradar.io	soc@letsdefend.io	Compromised Account AL...	Allowed

In the details of the mail, it is stated that the password information of the user “test[**@**]letsdefend.io” was leaked. In line with this information, it can be said that the requests that triggered the alert are attack attempts. The fact that the requests come from India is the factor that caused the alert to be blocked. In other words, if a request came from an IP other than the restricted zone, the attack could have been successful. To confirm this situation, information about the restricted zone should be searched in the mail.

Monitoring	< restricted	OR	Detailed Search	
Log Management				
Case Management				
Endpoint Security				
Email Security				
Threat Intel				
Sandbox				

Date	Sender	Recipients	Subject	Final Action
Jul, 19, 2022, 11:45 AM	cloud@letsdefend.io	security@letsdefend.io	Unused AWS Regions	Allowed

The cloud team informed the security team about the restrictions they made on AWS environments in an e-mail sent to the security team in 2022. In the mail, it is seen that “Asia Pacific (Mumbai) - ap-south-1” is among the zones with restricted access. It is known that the IP that attempted the attack is located in India. This shows why the attack was blocked. If the attack did not come from the restricted zone, it could have been successful. However, if there was MFA (Multi-Factor Authentication) in the environment where the request came from, the attack could have failed. However, the attack was blocked in the firewall before it reached that stage.



Initial Access

There is information in the mail traffic that the user “test[@]letsdefend” is a compromised account that attempted to login to the system. Also, there are login attempts towards the target system with this compromised account. Although access attempts towards the target system are blocked, it can be said that the External Remote Services technique was used for the initial access. When such services are opened to remote access, some basic actions should be taken in the structure. One of them is to enable MFA (Multi-Factor Authentication) in the services.

Compromised Account Information

Status: Action Waiting

Keyword: letsdefend, similarity

Compromised Domain: letsdefend[.]io

Affected Account: test@letsdefend.io

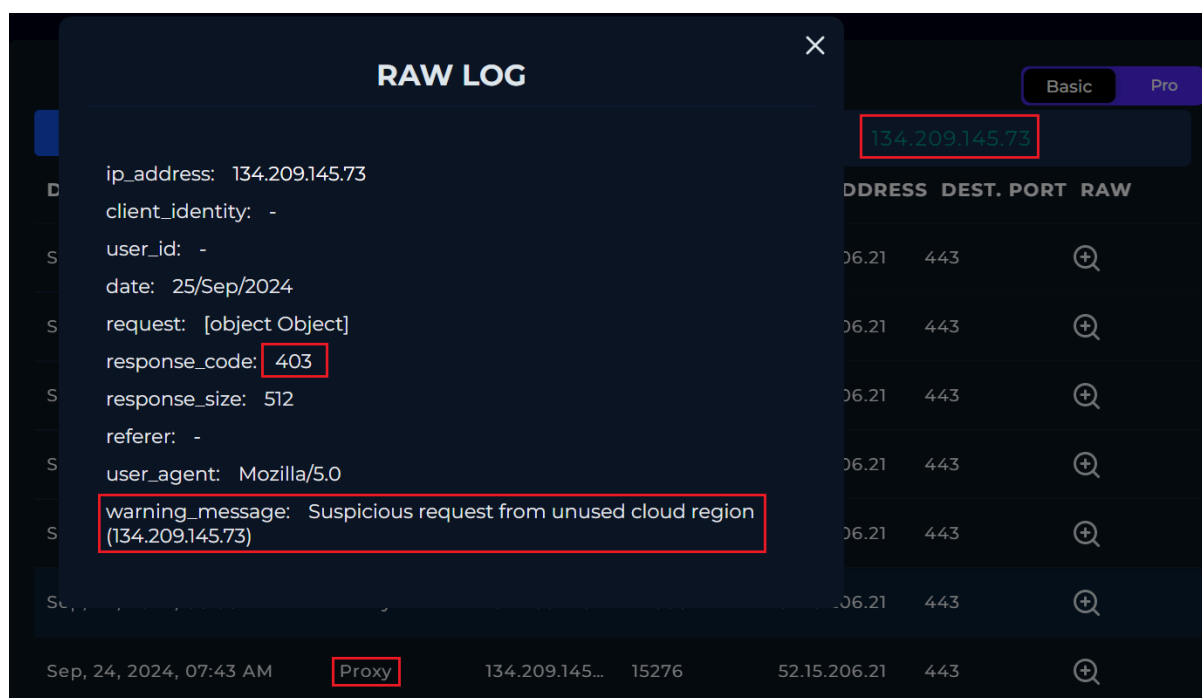
Detection Source: CTI alert system

Password: te*****12

Creation Date: Fri, 22 Sep 2023 08:19:04 GMT

Expiration Date: Sun, 22 Sep 2024 08:19:04 GMT

All logs of the attacker IP should be examined in detail. When the IP “134[.]209.145.73” is searched in Log Management, both firewall and proxy logs are seen. Looking at the details of the proxy logs, it is seen that the request failed with the error “Suspicious request from unused cloud region”.



In addition, the detail of the log shows that the response code is 403. The hxxp response code 403 means "Forbidden". This indicates that the server understands the request made by the client, but refuses to authorize it. The main reasons for receiving a 403 error typically include:

Access rights are missing or restricted: The server is denying access to the requested resource because the client (such as a browser or a script) does not have the necessary permissions.

IP-based restrictions: Access might be blocked due to geo-location restrictions (like region-based blocks, as in your earlier example).

Incorrect authentication credentials: Sometimes, the request may lack proper authentication credentials, or the provided credentials do not grant the client access. In essence, 403 errors are triggered when users are authenticated but do not have the necessary rights to view the content or access the resource. This is different from a 404 (Not Found) error, which indicates that the resource doesn't exist or is unavailable.

Resource: <https://developer.mozilla.org/en-US/docs/Web/http/Status/403>

The playbook questions can be answered now that the alert review is complete. The first question is about OS (operating system). Search for IP (52[.]15.206.21) in the alert in Endpoint Security to answer this. Here the OS of the relevant system is seen as "Ubuntu 20.04.02".

Determine the OS (Operating system)

What is the Operating system of the endpoint in the alert details?

Linux

Windows

The next question asks the Defense Evasion technique which was used in the alert. The situation that caused the alert to occur is that there are too many requests coming to the target system via India-located IP in a short time. This caused an alert on SIEM due to the traffic coming from the restricted zone. This hits the Unused/Unsupported Cloud Regions technique among defense evasion tactics.

Determine the type of Defense Evasion Techniques Involving Obfuscation and Concealment

Based on the analysis conducted on endpoint security and log management, which Defense Evasion techniques does the attack involve?

BITS Jobs

Deobfuscate/Decode Files or Information

Direct Volume Access

Hide Artifacts

Network Boundary Bridging

NONE

Obfuscated Files or Information

Pre-OS Boot

Reflective Code Loading

Unused/Unsupported Cloud Regions

The next question asks if an IOC was encountered when examining the alert. The answer to this is also positive because the alert occurred due to the attacker IP "134[.]209.145.73".

IOC Analysis

During the investigation, use Log Management logs and Endpoint Security to hunt for attacker IOCs. Evaluate whether any IOCs found are suspicious based on their behavior and reputation. Have you encountered any IOCs?

No

Yes

The next question asks whether the reputations of the obtained IOCs are suspicious. The related IP is reported in AbuseIPDB and VirusTotal in categories such as malicious, SSH, phishing, and brute force in different sources. In addition, the related IP is seen to be located in India.

IOC Reputation Check

Check the attacker's IOC reputation. You can use the following resources:

- [Virus Total](#)
- [AbuseIPDB](#)
- [LetsDefend TI](#)

Is the IOC suspicious or not?

No

Yes

The following question asks how many different systems the attack spread to. When the logs of the attacker IP that infiltrated the system with brute force are searched on Log Management, only 52[.]15.206.21 is seen as the destination IP. This proves that only one system in the network was affected.

Determine the Scope

On endpoint security, log management and email security systems, examine the IoCs identified during the investigation. If these IoCs are also present on other devices, those devices should be considered affected. Is there more than one affected device?

The last question asks if the system should be isolated from the network as a result of the examinations. According to Virus Total and AbuseIPDB, it is reported in bad web attack, brute-force, SSH, and malicious categories. However, since the IP that sent the requests is in the restricted zone, all incoming requests were blocked in the firewall and proxy. Since all requests failed, there is no need to isolate the target system from the network.

Should the device be isolated?

Systems that have been exposed to a cyber-attack should be isolated to reduce the impact of the cyber attack. Should the device be isolated?

Containment

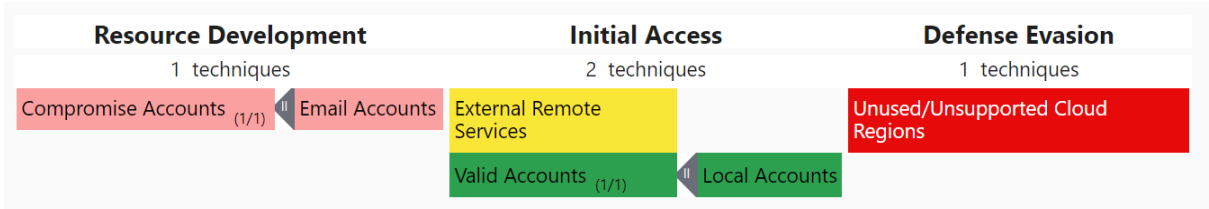
The attacker IP was reported in bad web attack, brute force, SSH and malicious categories according to Virus Total and AbuseIPDB. However, since the IP that sent the requests is in the restricted zone, all incoming requests were blocked in the firewall and proxy. You do not need to isolate the target system from the network due to the failure of all requests.

Lesson Learned

- Access to Remote IPs should not be given if it is not within the scope of work or the whitelisting method should be applied on security devices.
- Systems open to the outside world should be patched regularly.
- Routine scans should be carried out to find out if the systems are affected by vulnerabilities.
- Effective monitoring and logging can detect and help mitigate attacks early in the process.
- In structures open to remote access, zone restrictions should be applied for areas that are thought to be free of traffic within the scope of the work.
- MFA (Multi-Factor Authentication) should be activated in services open to remote access.
- In services open to remote access, default (test, admin) users should not be left enabled.

Appendix

MITRE



Artifacts

Field	Value
IPs/URLS	134[.]209.145.73
Users	test[@]letsdefend.io
Host/IP	AWS_Services/52[.]15.206.21